

# GAUNTLET: A CLOSED-LOOP ADVERSARIAL SIMULATION FRAMEWORK FOR GENAI-ENABLED PAYMENT FRAUD

**Shehryaar Shah Khan   Saksham Tiwari   Animesh Raj  
Eisa Shaiju   Monika Kumari**

Team-BandOfTheHawk  
Indian Institute of Technology Kharagpur, West Bengal, India

## ABSTRACT

Payment fraud detectors are fitted to fraud that has already occurred, and generative models have lowered the cost of the capability steps preceding a fraudulent authorisation, so the attacks arriving now differ from those in any historical label set. We present GAUNTLET, our submission to the Mastercard Innovation Challenge 2026: a closed-loop simulator in which a learned attacker and a retraining detector adapt against each other inside a synthetic payment world calibrated to real transaction data. The attacker is a reinforcement learning policy trained with proximal policy optimisation from behaviour-cloned demonstrations, not a language model driven around an orchestration loop, and we argue that choice on grounds of credit assignment, measurable improvement against a moving opponent, and reproducibility. Across four paired seeds the loop produces co-evolution in five of eight runs, with extraction rising above its opening level, a defender refit suppressing it, and the attacker recovering; ablating the attacker’s stealth capability costs it 1,639 in mean post-refit extraction, with a 95% bootstrap interval of  $[+219, +2764]$ . Strategy diversity rises from one or two converged sequences before the first refit to between four and eight by the last, and the policy switches binding tactic under pressure, converging in some runs on a quiet account-takeover route that the detector’s device-novelty signal does not cover. The defender operates under a business cost curve and refuses 0.67% of genuine authorisations, so its gains are constrained by the friction it imposes rather than by recall alone. The defender architecture deploys without the simulator; the simulator is a pre-deployment red-team harness that runs on one GPU in hours.

## 1 INTRODUCTION

A fraud detector learns the shape of the fraud in its training window. This works while attacks change slowly. It degrades when the cost of mounting a new kind of attack falls sharply, because the detector has no examples of what arrives next and no way to acquire them until losses have already been taken.

The scale is not small. European authorities report EUR 4.2 billion in payment fraud across 2024, with card fraud on EEA-issued cards up 29% year on year ([European Banking Authority and European Central Bank, 2025](#)), and UK Finance reports GBP 572.6 million in unauthorised card fraud over the same period ([UK Finance, 2025](#)). Generative models have produced exactly the kind of cost drop that moves those figures, and the drop is concentrated in the steps before the money moves. Cloning a voice for an interactive voice response call, producing a document that passes an automated onboarding check, and writing a dispute narrative that reads like a real customer were all specialist tasks a few years ago. Each is now a query. The authorisation at the end of the chain looks much as it always did, which is precisely the difficulty: the novelty sits in the capability acquisition, and the transaction-level features a detector reads were designed for a world where that acquisition was expensive.

Testing a detector against this requires attacks that do not exist in any labelled dataset. Two responses are available. One is to script the attacks by hand, which measures the imagination of whoever wrote

the scripts. The other is to let an attacker learn against the detector and observe what it finds. We take the second, and the contribution is a system in which that learning is well-posed: the world is calibrated, the observation boundary is enforced, the economics are bounded, and the defender adapts in response.

### 1.1 CONTRIBUTIONS

1. A synthetic payment world calibrated against real transaction data, with benign fidelity reported as a degradation ratio against a measured real-data noise floor, not as an unanchored distance.
2. A taxonomy of nine generative-AI-enabled fraud verticals expressed over one shared action space of twenty actions and a four-stage capability model, so that verticals differ in strategy alone.
3. An attacker that is a learned policy rather than a prompted agent, trained by proximal policy optimisation from behaviour-cloned scripted demonstrations, which improves measurably against a detector that retrains underneath it.
4. A closed red/blue loop in which the defender operates under a business cost curve, so its gains are constrained by the friction it imposes on genuine customers, not by recall alone.
5. Measured emergent attacker strategies, including binding tactics and operational postures that no script encoded, read from the policy's own converged action sequences.

### 1.2 WHY A LEARNED POLICY AND NOT AN AGENTIC LOOP

The obvious way to build a generative-AI attacker is to place a language model in an orchestration loop, give it tools, and let it plan. We built the attacker as a reinforcement learning policy instead. The reasons are technical and worth stating before the system description, because they shape everything after it.

**A prompted loop does not optimise.** A language model asked to choose the next action samples from a prior fixed when it was trained. It carries no gradient, no value estimate, and no mechanism by which its thousandth episode against a particular detector is better than its first. The property we need is improvement against a specific, moving opponent. Section 8 reports that improvement as a measured curve; a prompted loop has nothing that would produce one.

**Credit assignment is the problem, not a detail.** Payment fraud is sequential and sparsely rewarded. Credentials are bought, a device is bound, an authorisation is attempted, and value lands or a chargeback arrives much later. Attributing an eventual cash-out to a binding decision taken fourteen actions earlier is the specific job of generalised advantage estimation and a learned critic ([Schulman et al., 2016](#)). A prompt chain has no equivalent construct; it can describe a plan but cannot apportion outcome across it.

**Cost, determinism, and the ability to ablate.** One policy update at the scale reported here costs no API calls. An agentic attacker running twelve thousand episodes costs thousands of calls, does not reproduce under seed, and cannot be held fixed while one component is removed. The controlled comparison in Section 8.3, which is what licenses the claim that the stealth capability matters, is unavailable in that design.

**Reward hacking is the desired behaviour.** A learned policy finds whatever the simulator actually permits, including paths its designers did not intend. For a red-team harness that is the point. The episode integrity controls in Section 5.5 exist because a policy given an unbounded economy will locate the unbounded part and exploit it, which is a hole a real attacker would also find. A model prompted to behave plausibly does not probe the boundary.

**Generation is still used, where content is inspected.** The division is explicit. Where a control examines an artifact, which is a dispute narrative, a support ticket, a refund claim, a voice sample, or an identity document, real model output is generated and scored. The decision of which action to take next is learned. Section 5.4 describes the interface between them.

## 2 RELATED WORK

**Features for card fraud.** Bahnsen et al. (2016) report that per-card aggregates over a rolling window, conditioned on a second matching criterion such as merchant category or entry mode, raised realised savings on a production system by 252% over the raw transaction features, and that adding a von Mises periodic model of transaction hour raised it a further 13%. The aggregation strategy originates with Whitrow et al. (2009). GAUNTLET carries this feature class in its event schema, which matters here for a reason beyond detection accuracy: a simulator whose benign traffic lacks per-entity structure in amount and hour cannot exercise those features, and a detector evaluated on it would report a score the real world will not reproduce.

**Evaluation discipline.** Dal Pozzolo et al. (2014) argue from a European processor’s production data that accuracy and area under the ROC curve are the wrong targets when investigators review only the top-ranked alerts, and recommend average precision and precision at a fixed alert budget. They also compare incremental retraining schemes and find that forgetting old genuine traffic while retaining fraud outperforms both static models and naive updating. GAUNTLET adopts both: PR-AUC is the primary metric, and the retention buffer is asymmetric by construction (Section 6.3).

**Risk-based authentication.** ? analysed 31.3 million login attempts from 3.3 million users and calibrated a likelihood-ratio risk score over feature vectors, with IP weighted 0.6, autonomous system number 0.3, and country 0.1. Two of their findings inform this work directly: user activity is sparse, with a median of two logins per user and 48.3% logging in less than monthly, and a user’s setup stabilises after only four to eight historical events. The first is why the simulator models dormancy explicitly; the second sets the warm-start depth. The underlying scoring model is due to Freeman et al. (2016).

**Synthetic transaction generators.** PaySim (Lopez-Rojas et al., 2016) simulates mobile money transfers and is widely used for anti-money-laundering work. Tide (?) generates anti-money-laundering datasets with configurable structural and temporal graph patterns, which is the right target for that task and a different one from ours: laundering is a property of how value moves through a network, while card fraud is a property of how one entity behaves against its own history. ? find that tabular generators fail to preserve behavioural fraud patterns, so detectors trained on their output score well and transfer poorly. That failure is the target of the fidelity protocol in Section 3.3, which measures per-entity structure instead of marginal distributions.

## 3 DATA AND CALIBRATION

### 3.1 DATASET ROLES

Four public sources are used, each for the one thing it can support. Splitting roles across sources, instead of fitting and holding out within one source, tests cross-dataset transfer, and keeps a dataset’s known artifacts from propagating into parts of the world it should not touch. Table 1 lists the assignment.

The exclusions are as deliberate as the inclusions. Sparkov’s generator visits 572 of 693 merchants per simulated card, giving a top-merchant share of 0.67% where real cardholders concentrate heavily, and places transactions in a geographic annulus with a 35 km tenth percentile. Its category taxonomy is sound; its behaviour is not, so only the taxonomy is taken. The CFPB corpus is truncated at 2022 because complaints from 2023 onward constitute 63% of the corpus and carry unknown language-model authorship. Contaminating a corpus whose purpose is to represent human writing would undermine the one measurement it supports. The post-2022 portion is retained separately as a contamination probe.

### 3.2 PARAMETER PROVENANCE

Every parameter carries one of four provenance classes, enforced during configuration resolution, not asserted in prose. FITTED parameters are estimated from a named dataset. SWEPT parameters are unmeasurable from available data and are varied across a stated range, with any claim required to hold across the whole range. CITED parameters come from a published source. FREE parameters are design choices tuned until the simulation behaves, and are never presented as empirical. The

Table 1: Dataset roles. Each source supplies only what it can support.

| Source                                                                                           | Role                                                                                                                                                                          | Licence       |
|--------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------|
| IEEE-CIS ( <a href="#">IEEE Computational Intelligence Society and Vesta Corporation, 2019</a> ) | Noise floors, amount shape and tail, per-card heterogeneity, inter-arrival timing, per-entity hour structure, device fan-out. 590,540 transactions over 13,553 card entities. | Kaggle terms  |
| Sparkov ( <a href="#">Harris, 2020</a> )                                                         | Merchant category taxonomy only: 14 categories mapped to 8 clusters. Not used for timing, geography, per-category amounts, or merchant loyalty.                               | CC0           |
| PaySim ( <a href="#">Lopez-Rojas et al., 2016</a> )                                              | Transfer and layering topology for the mule verticals. Not used for benign behaviour.                                                                                         | CC BY-SA      |
| CFPB ( <a href="#">Consumer Financial Protection Bureau, 2025</a> )                              | Human-written complaint narratives as the text negative class and the template-similarity reference corpus. Restricted to 2022 and earlier.                                   | Public domain |

Table 2: Benign fidelity as a degradation ratio against the real-data noise floor. Higher is better; 1.0 is indistinguishable from real.

| Layer                | Real  | Generated | Ratio |
|----------------------|-------|-----------|-------|
| Hour, marginal       | 0.416 | 0.434     | 0.96  |
| Hour, within-entity  | 0.459 | 0.492     | 0.93  |
| Hour, between-entity | 0.715 | 0.792     | 0.90  |
| Device fan-out, mean | 8.14  | 8.06      | 0.99  |

current calibration artifact holds 8 fitted models over 63 parameters, 9 swept ranges, 16 measured noise floors, and 19 measured behavioural targets.

The distinction does real work in the results. Reward weights are FREE, so no claim rests on their values. Risk band boundaries begin FREE and become CITED by grid search against a published cost curve, which is a stronger position than reporting round numbers and calling them thresholds.

### 3.3 BENIGN FIDELITY

A synthetic world that is too uniform hands the detector free signal. Reporting a raw distance between generated and real distributions does not detect this, because there is no scale on which to judge the distance. GAUNTLET reports fidelity as a ratio: the distance between generated and real data, divided by the distance between two disjoint halves of the real data split by entity. A ratio of 1.0 means the generated data sits as close to real as real data sits to itself. Wasserstein-1 is the primary distance, chosen over the Kolmogorov-Smirnov statistic because the latter is insensitive to tail behaviour, and a circular variant is used for hour-of-day. Inter-arrival timing is fitted as a self-exciting point process using the closed-form likelihood of [Ozaki \(1979\)](#) with the linear-time recursion of [Ogata \(1981\)](#), which makes per-entity fitting across the reference dataset tractable.

Table 2 reports the result per layer.

Two failure modes are provable in advance, and are guarded structurally rather than checked afterwards. Assigning device-to-card edges independently per row caps the resulting degree dispersion at a variance-to-mean ratio of 1.0, against a measured 112.5 in the reference data, so the graph is generated degree-first from the measured degree distribution. Separately, marginal metrics cannot detect per-entity error: a population can reproduce the pooled amount distribution exactly while every individual card spends identically. The measured split is 39% of amount variance between cards and 61% within, and the protocol compares both components separately, within matched history bands and with a small-sample correction. Without that correction the measured per-entity hour concentration drifts from 0.565 to 0.496 purely as a function of the minimum event count applied. That drift is an artifact of sparsity, not a property of the population.

Table 3: The nine verticals, over one shared action space.

| Vertical            | Stage     | Generative capability                 |
|---------------------|-----------|---------------------------------------|
| Card testing        | BOUND     | None; volume and velocity             |
| Voice clone         | ACQUIRED  | Speech synthesis for IVR provisioning |
| Deepfake onboarding | ACQUIRED  | Face and document synthesis for KYC   |
| Agentic phishing    | NONE      | Personalised outreach at scale        |
| Friendly fraud      | MONETIZED | Dispute narrative writing             |
| Support engineering | ACQUIRED  | Pretext and ticket writing            |
| SIM swap            | ACQUIRED  | Carrier pretext writing               |
| Mule layering       | MONETIZED | None; transfer topology               |
| Refund abuse        | BOUND     | Refund claim writing                  |

## 4 A TAXONOMY OF GENAI-ENABLED PAYMENT FRAUD

### 4.1 THE CAPABILITY MODEL

Every attack in GAUNTLET moves through the same four stages: NONE, ACQUIRED, BOUND, and MONETIZED. An actor at NONE holds nothing and may only obtain a means, whether by purchasing credentials, phishing a holder, or assembling a synthetic identity. An actor at ACQUIRED holds a means it cannot yet spend, and must bind it to something usable through device provisioning, an interactive voice response call, a document submission, a SIM swap, or a password reset. Only at BOUND can value move. MONETIZED permits extraction and laundering.

Stage gating is structural rather than learned. Spending a card that nobody has bound is not a strategy that fails; it is an event that cannot occur. Encoding that in a legality mask keeps a learning policy from spending capacity rediscovering it, and keeps the resulting action sequences readable. Twenty actions span the four stages, each carrying a cost, and the mask is applied to the policy’s logits before the softmax so no probability is ever placed on an impossible action.

### 4.2 THE NINE VERTICALS

Table 3 lists the verticals. They share one action space and differ in strategy, which is what makes them comparable: a per-vertical recall figure then reflects a difference in behaviour, not one in machinery. The third column names the step where a generative model changes the attacker’s cost.

Merchant collusion and bust-out are described in the design and excluded from simulation. Modelling them requires a settlement and clawback layer the money model does not implement, and no available source carries merchant onboarding or settlement data, so every parameter would be invented. Describing an excluded vertical is more useful than simulating one on fabricated numbers.

## 5 THE GAUNTLET SIMULATOR

Figure 1 shows the loop as a whole. The subsections that follow describe each stage of it, and Sections 6 and 7 open the two boxes it leaves closed.

### 5.1 WORLD MODEL

The world holds cardholders, cards, devices, accounts, merchants, and payees, connected by typed edges: a card is provisioned to a device, a payee is added to an account, a holder owns cards and accounts. Merchants carry a risk tier and a liquidity flag, since converting stolen value at a gift-card merchant differs from doing so at a grocer. Transaction-mode shares follow the Federal Reserve Payments Study ([Board of Governors of the Federal Reserve System, 2024](#)).

The device graph is generated degree-first. A degree is drawn per card from the measured distribution and edges are then assigned to satisfy it, instead of assigning each edge independently. The reason is given in Section 3.3: independent assignment cannot produce the measured dispersion, and no amount of tuning fixes that, because it is a property of the generative procedure rather than of its parameters.

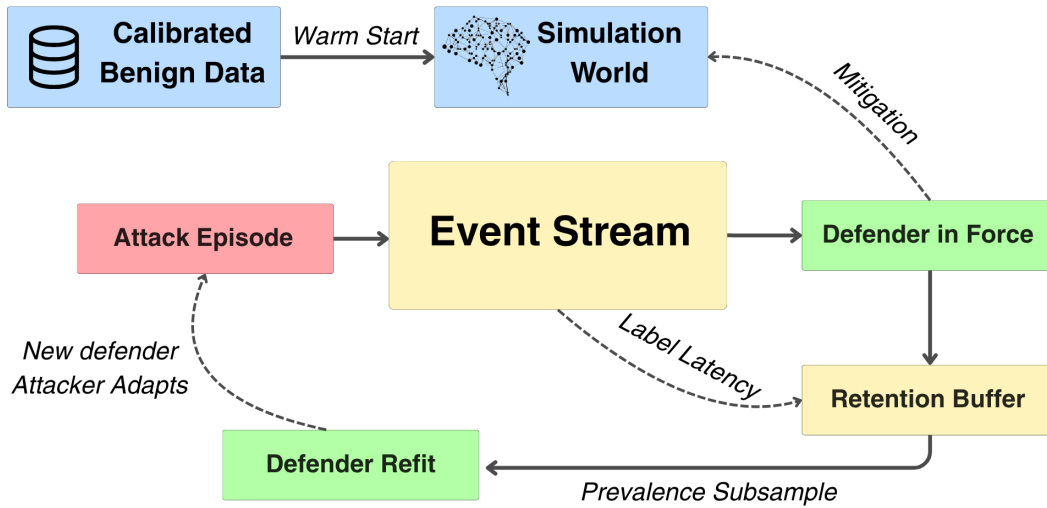


Figure 1: The GAUNTLET loop. Calibrated benign data warm-starts the simulation world, which gives device ages, running medians, and velocity windows a history before any measurement begins. Attack episodes and benign traffic both write into one event stream, and the defender in force scores every event as it arrives; its mitigations write back into the world, so a removed capability is genuinely gone. Labelled events reach the retention buffer only after the label latency has elapsed, which models the lag before a chargeback lands. The defender refits from that buffer, with the retained positives first thinned to a stated prevalence, and the attacker then adapts against the new defender, closing the loop. Sections 6 and 7 open the two boxes this figure leaves closed.

A warm start fills the world with backdated history before any measurement window opens. It runs through the same step method that live traffic uses, rather than writing state directly, so device ages, running medians, and velocity windows are populated by the same code path that will later read them. Warm-start rows are flagged and excluded from training, because they are feature-poor by construction: the history they would read is the history they are creating.

## 5.2 EVENTS AND THE BLINDNESS RULE

The event builder cannot know who acted. It sees a card, a device, a merchant, an amount, and the state of the relevant velocity windows, and it emits an event carrying only those. Whether the actor was a cardholder or an adversary is never a field on an event. Labels are stamped after an episode closes, at which point the outcome is known and the event is already written.

This matters because the alternative leaks. An event carrying its own label, even indirectly through a field only adversarial actors populate, gives the detector the answer and produces a detection score that describes the leak. Building and committing are also separated: an event is built from the window state as it stood before the event, then committed into that state afterwards, so a transaction never counts itself in its own velocity features.

## 5.3 ACTION SPACE

Twenty actions span the four stages. Five acquire a means, eight bind it, four spend, and three extract. Each action carries a cost, because a free action invites a policy to spam it and the resulting behaviour describes the reward function instead of fraud. Actions that need rendered content declare it: a phishing contact, a support ticket, a refund claim, a dispute, a voice sample, and a face sample all request an artifact from the generative layer before they resolve.

Appendix C lists all twenty with their stages and costs.

Every resolver either performs its mutation or fails. An earlier design allowed an action to report success while changing nothing, which produced a log that contradicted the world: an event said



a device had been bound while the graph held no such edge, and the next authorisation failed for a reason nothing in the log explained. Stage advancement is conditional on the mutation actually happening.

#### 5.4 GENERATIVE LAYER

Three verticals put written text in front of a control that reads it: a disputed charge, a support request, and a refund claim. For those, GAUNTLET generates the artifact with a language model rather than sampling a score to stand in for one. Dispute narratives, support tickets, and refund claims are produced by Qwen-2.5-7B-Instruct, and each artifact is embedded with Qwen3-Embedding-0.6B (Qwen Team, 2025), truncated to 256 dimensions through the model’s Matryoshka property so the text expert reads a vector of the same width regardless of what the generator produced.

The artifact interface is a single call that takes a tool name, a target reference, and a capability tier, and returns rendered content with its scores. What sits behind that call is a deployment choice rather than an architectural one. A live model invocation satisfies the interface, and so does a remote API, which is what a production harness fitted to an issuer’s own traffic would most likely use. For the experiments reported here the pool is generated once, offline, keyed by vertical, capability tier, persona, and class, and the call becomes a lookup. Two reasons make that the right choice for measurement rather than for deployment. A co-adaptation run issues on the order of a hundred thousand artifact requests across its updates, and paying generation latency on each would dominate the wall-clock time of an experiment whose purpose is to compare policies. More importantly, a simulation that calls a sampling model on its hot path is not reproducible under seed, and every controlled comparison in Section 8 depends on two arms differing in exactly one component.

Fraud and benign artifacts come from one template. The negative twin of a fraudulent dispute is a real customer disputing a charge they did not authorise; the letter reads the same, and the difference lives in whether the underlying transaction was genuine, which is a fact the episode label records and the text does not contain. Drawing the two classes from separate templates would teach the text expert to recognise a template, and the reported score would describe that rather than fraud. Appendix A gives every prompt and marks the single clause that differs.

Three scores accompany each artifact and are what the text expert consumes. Template similarity compares the artifact against the CFPB human corpus and against other artifacts at the same tier. Entity consistency checks the amounts, dates, and merchant names in the text against the event fields the artifact accompanies. A perplexity proxy scores fluency. All three are measured on the generated output rather than assumed from the tier that produced it, which is what keeps the capability ladder from being circular: the tier is defined by the prompt, and its effect on the scores is an observation.

Voice and document verticals draw on an image and speech generation model, whose detector-facing scores enter through the same artifact interface. That component is developed separately and no result in this paper depends on it.

#### 5.5 EPISODE INTEGRITY

A learned policy optimises whatever the simulator actually rewards, so the simulator’s economics must be bounded before its output means anything. Five controls do that work, and each is verified by a test asserting it changes what the world permits.

*An action cap* ends an episode after forty actions. *A per-action cost* means no action is free. *A per-merchant value ceiling* bounds what one merchant will absorb within an episode, which is what forces an attacker spreading value to move between merchants instead of repeating at one. *An episode duration cap* bounds wall-clock time, so a policy cannot stretch an episode across months until a new device ages into an ordinary one and the velocity windows forget what came before. *Per-episode threshold jitter* perturbs the defender’s decision boundaries by a small amount drawn once per episode, so a policy cannot locate a fixed threshold and sit beneath it.

Alongside these, the top action sequences are logged and read at every round. Each logged action carries what the world did with it, marking those the stage forbade and those that failed, because a sequence log that records intent rather than outcome overstates what happened and will be believed.

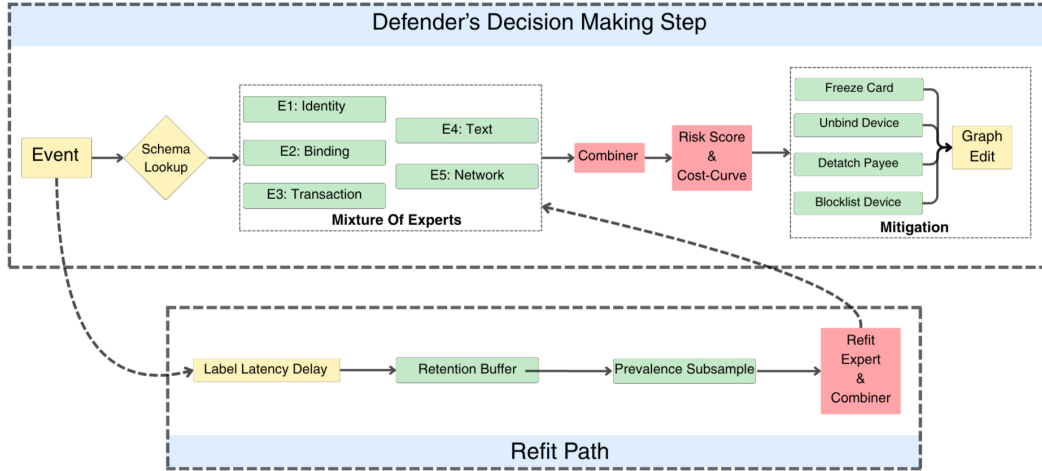


Figure 2: The defender. An event is routed to the experts its type admits, which is a schema lookup rather than a learned gate; the applicable experts’ scores are combined by a learned model; and the resulting score is banded against a business cost curve into an action and its mitigations, which write back to the entity graph. The refit path below carries the event stream through label latency, asymmetric retention, and prevalence subsampling before the experts and combiner are fitted again.

An absurd sequence indicates a simulator hole, not a clever attacker, and holes found this way are worth closing, since a real attacker would find them too.

## 6 THE DEFENDER

Figure 2 gives the architecture. Three properties of it are argued below: that routing is a lookup and not something to learn, that the thresholds sit on a cost curve rather than at round numbers, and that a mitigation changes the world rather than raising an alert.

### 6.1 FIVE EXPERTS, ROUTED BY SCHEMA

The obvious detector for this problem is a single model over a single table, and the reason GAUNTLET does not use one is a property of the event schema rather than a preference for ensembles. The event types carry structurally different feature spaces. A KYC submission has no amount and no merchant. An authorisation has no liveness score. A dispute carries a text embedding that appears on no other event type. Flattening all fourteen types into one matrix therefore produces a table in which most cells are null for most rows, and the pattern of which cells are null is a near-perfect indicator of the event type. A single model fitted to that table learns the null pattern first, because it is the cheapest available signal, and what looks like detection is partly type identification.

Five experts partition the space along the boundaries the schema already draws. The identity expert covers onboarding and interactive voice response events. The binding expert covers device provisioning, SIM changes, password resets, payee additions, and support tickets, which is the set of events by which an attacker converts a stolen credential into a usable capability. The transaction expert covers authorisations and transfers. The text expert covers the three artifact-bearing types. The network expert covers every type, since the graph-derived fan-out features are stamped on every event and are the one feature space that is genuinely universal.

Model choice follows the feature space rather than a uniform default. The identity, transaction, text, and network experts are gradient-boosted trees (Chen & Guestrin, 2016), which suit dense numeric features with interactions the modeller has not specified in advance. The binding expert is a calibrated logistic model, following the likelihood-ratio formulation that was calibrated on 31.3 million real logins. The choice there is deliberate: binding events are sparse per entity, the useful signal is a ratio of how



unusual a feature vector is against how usual it is for this user, and a tree fitted to a few hundred positives will find splits that a likelihood ratio will not pretend to.

Which experts apply to a given event is a dictionary lookup on its type. This is worth stating plainly because the natural instinct is to learn it. A gating network trained to route events to experts would reach near-perfect accuracy on this task, and it would deserve no credit for doing so, because the routing is a schema fact that the event already declares. Learning it consumes parameters, introduces a failure mode where the gate misroutes an event to an expert that has never seen its feature space, and improves nothing. What is genuinely unknown, and therefore what is learned, is how much weight to place on each applicable expert's opinion once they disagree. That is stacked generalisation (Wolpert, 1992). Calling the architecture a mixture of experts would be the more fashionable description and the less accurate one, since the defining feature of a mixture is precisely the learned gate this design does without.

## 6.2 RISK BANDS UNDER A COST CURVE

The combiner emits a score in  $[0, 1]$ . Turning that into a decision requires thresholds, and where those thresholds sit determines what the detector actually does. Four boundaries separate five actions: approve, step up to a challenge, hold for review, decline, and block.

Consider what happens when those boundaries are left at round numbers, which is the common practice and was the initial implementation here. The detector is then evaluated on one axis, which is how much fraud it catches, and it has exactly one way to lose, which is to miss some. Under a single loss condition the optimal policy is degenerate: tighten every threshold until nothing is approved. No fraud is missed and the detector scores perfectly on the only quantity being measured. That such a detector is useless is obvious to a practitioner and invisible to the evaluation.

The consequence for an adversarial simulation is more specific than a bad operating point. If the defender may tighten without cost, then any co-adaptation result is confounded, because the defender's apparent skill and its willingness to refuse are the same quantity. An attacker losing ground cannot be distinguished from an attacker facing a detector that has simply become stricter.

GAUNTLET therefore grid-searches the four boundaries at every refit against a cost curve that charges a missed fraud its realised value, a stepped-up genuine customer a friction cost, and a held one an analyst review cost. The two cost figures are vendor-sourced order-of-magnitude estimates, which is why no dollar return is claimed anywhere in this paper; what the search needs is their ratio and not their absolute size. A detector that must remain usable is what leaves an attacker any room at all, and it is what makes the friction rate in Section 8.5 a meaningful accompaniment to the extraction curve rather than a decorative statistic. One concession is stated rather than hidden: the search runs on the training set, so the thresholds see rows the model was fitted on. At the prevalence used, a held-out split leaves too few positives to place four thresholds on with any stability.

Bands drive write-back into the graph, which is what distinguishes a mitigation from an alert. A hold freezes the card. A decline or block deletes the binding the event ran through and blocklists the device. The effect is that a subsequent authorisation fails because the card has no usable binding, and not because a rule fired a second time. An attacker that loses a device to a blocklist must acquire another one, paying the action cost and emitting the events that acquisition produces. This is what closes the loop at the level of the world rather than at the level of the score.

## 6.3 ASYMMETRIC RETENTION AND LATE LABELS

Fraud is rare and every example is signal, so fraud is retained across refits. Benign traffic drifts, and old benign teaches a world that no longer exists, so only recent rounds are kept. This follows the Forget scheme of Dal Pozzolo et al. (2014), and is implemented by changing what the model has ever seen, not by reweighting a loss.

Two handicaps sit alongside it, both present so that an adapting attacker has room. Labels arrive late, modelling the lag before a chargeback lands, so a refit is always fitted to a picture of the attack that is already stale. Fraud is retained for a bounded number of refits, not forever, because a detector that never loses a pattern means an abandoned tactic can never profitably return, and real fraud models are retrained on windows.

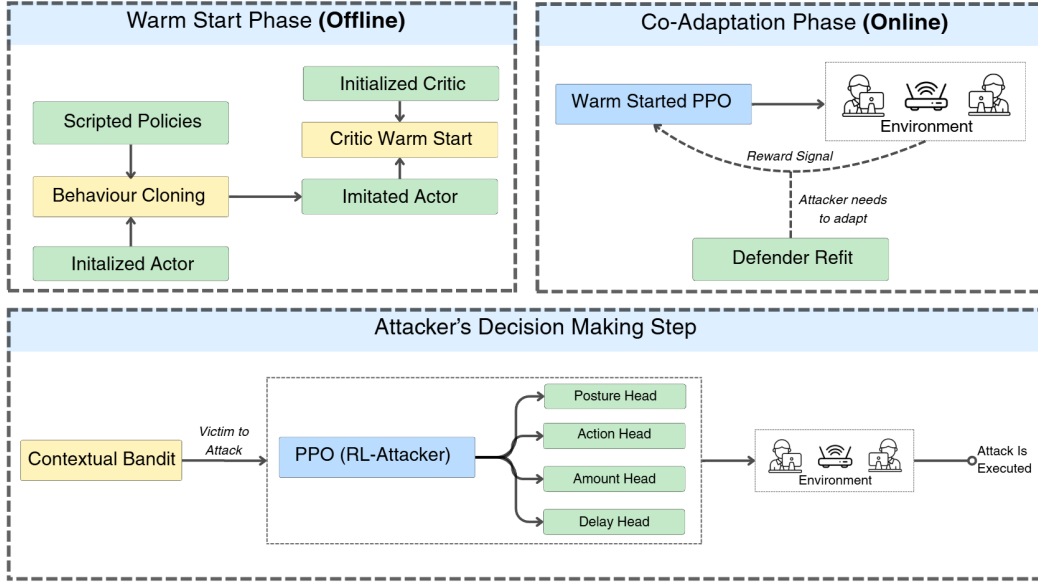


Figure 3: The attacker. The offline warm-start phase clones an actor from scripted demonstrations and fits a critic separately on realised returns, both against a frozen defender. The online phase then alternates policy updates with defender refits, so the opponent the policy faces changes underneath it. The lower strip shows one decision: the contextual bandit selects a victim on dump-knowable features, the policy emits an action, a posture, an amount and a delay from a shared trunk, and the environment resolves the posture into a concrete device, entry mode, delay floor and card before executing the attack.

The assembled training set is held to a stated fraud share by subsampling positives. Prevalence left to whatever the loop happens to produce is not a property of the deployed problem, and a detector fitted at a high fraud share is solving an easier one. Subsampling removes only positives: generating benign to reach the target would need on the order of six hundred thousand additional rows per refit window, and discarding benign would throw away the negatives that make the problem hard.

## 7 THE LEARNED ATTACKER

Figure 3 gives the two training phases and the decision the policy makes at each step. The order of the warm-start stages is the subject of Section 7.1, and the posture head, which is the component that separates this attacker from the one it replaced, is the subject of Section 7.3.

### 7.1 WARM-START ORDER

Two distinct things in this system are called a warm start. The world warm start of Section 5.1 fills the simulated population with backdated history. The agent warm start described here trains the attacker’s actor and critic before any policy-gradient update runs. They share a name because both exist to avoid a cold start, and they are otherwise unrelated.

A policy initialised from random weights does not learn this task. The reason is arithmetic rather than a matter of tuning. Reaching a cash-out requires a coherent sequence of roughly four correct decisions from a masked space of twenty actions, and the reward before that point is negative, since every action costs something and most early actions fail. A random policy therefore encounters a positive return perhaps once in tens of thousands of episodes, receives a steady negative signal in the meantime, and converges on the strategy that minimises cost, which is to stop acting. We observed exactly this before the warm start was in place.

The order in which the components are trained matters, and each step exists because the step after it fails without it.

The defender is fitted first, on benign traffic and a first sweep of scripted fraud. An attacker trained against no opponent learns a strategy against an absent constraint, and the first refit then invalidates everything it learned.

The actor is then behaviour-cloned from stochastic scripted demonstrations. The scripts are deliberately stochastic, sampling amounts, delays, and merchants, because a deterministic demonstration set produces a clone with no entropy and policy gradient has nothing to explore from. The demonstrations are collected through the same environment interface the learned policy will act through, which is what makes them clonable at all: a script that read the actor's internal state directly would produce observation-action pairs the policy could never reproduce, since the policy does not see that state.

The critic is fitted next, separately, on realised returns-to-go from the cloned actor's rollouts. A value function cannot be cloned, because the demonstrations carry actions and not values. Leaving the critic at its initialisation instead would mean the first advantage estimates are differences against noise, and the first policy update would be in an arbitrary direction from a starting point that was expensive to obtain.

Only then does proximal policy optimisation (Schulman et al., 2017) begin, and for the first updates the surrogate carries a penalty on divergence from the frozen clone, annealed to zero. Without that penalty a single noisy early advantage estimate can move the policy far enough to discard the demonstrations entirely, which returns the run to a cold start having paid the cost of collecting them.

One rule governs what is cloned, and it cost us a result to learn. A head is fitted only where the demonstrations carry information about it. The scripted policies predate the posture head of Section 7.3 and are uniformly loud, so cloning the posture head fits it to a constant. Measured, this drove the posture entropy from 1.382 to 0.031, leaving the policy 99.6% certain of the one choice it most needed to question, and the divergence penalty then held it there through the first defender refit. The capability existed, was sufficient on its own to clear the decline threshold, and went unused. Fitting a head against data that does not speak to it manufactures a confident answer out of nothing.

## 7.2 THE OBSERVATION BOUNDARY

The policy observes the stage it occupies, the legal-action mask for that stage, and seven scalars: actions taken, value extracted, elapsed hours, the hour of day encoded as a sine-cosine pair, how many of its own actions have been refused, whether the last one was, and how much of its credential dump remains. It does not observe the graph, the defender's score, or any field the bank holds privately.

Each of those is a fact an attacker possesses without privileged access. An operator knows how many of its authorisations came back declined, because it saw them decline. It knows how many cards it purchased and how many it has burned. It can read a clock. The hour is included because the alternative is worse than excluding it: benign traffic follows a circadian pattern, and an attacker with no clock distributes itself uniformly across the day, which places a disproportionate share of its activity in hours when genuine volume is near zero. That is an artifact of the attacker's blindness rather than a property of fraud, and it hands the detector a signal no real adversary would concede.

The exclusions matter more than the inclusions. An attacker permitted to read the graph would know which devices a card is bound to, how many cards a device carries, and which accounts share a household. A policy with that information would learn a strategy no operator could execute, and the resulting success rate would characterise a problem nobody faces. An attacker permitted to read the defender's score would be performing gradient-free optimisation against an oracle, which is a study of the detector's decision surface and not of fraud. Both are easy to permit accidentally, since both are available in the simulator's memory at the moment the observation is constructed, and the boundary is therefore enforced by building the observation from a fixed key set rather than by convention.

## 7.3 THE POSTURE HEAD

The action head chooses what the attacker does. A second discrete head chooses how, across four postures: act without concealment, route the action through the card's oldest surviving binding, do the same after a cooling delay, or rotate to another card in the dump before acting.

This head was added in response to a measurement, and the sequence is worth recounting because it illustrates a failure mode that a co-adaptation study can easily mistake for a result. In the original

design the policy chose an action, an amount, and a delay. Every other field on the resulting action was fixed by the environment, including which of a card's bindings the authorisation ran through. The environment picked that binding with a preference for the most recently seen one, which is correct for benign traffic, since a replaced handset carries most of a holder's activity. For an attacker that had just provisioned a device, it meant every authorisation ran through a device minutes old.

The detector found this immediately. Device age dominated its feature importances, the first refit closed the path, and extraction collapsed and did not recover. The natural reading of that curve is that the defender had won. The correct reading is that the attacker's action space could not express the alternative. It was not failing to discover a stealthier strategy; there was no stealthier strategy inside its reachable set.

The head closes that gap without breaching the observation boundary. The policy emits an intent, and the environment resolves that intent into a concrete device identifier, entry mode, delay floor, and active card. The resolution reads the graph. The policy does not. That division is defensible on its own terms rather than as a convenience: an attacker who has taken over an account knows which device the victim habitually uses, and does not need the bank's device table to know it. Encoding that knowledge as an abstract posture, resolved world-side, keeps the policy honest while allowing the behaviour to exist.

The measured effect is large. Under the aged posture the median device age on a fraudulent authorisation moves from 18.5 days to 327, and the share of fraudulent authorisations running through a device less than a day old falls from 47% to zero. Sweeping a fitted detector confirms that this is sufficient rather than merely directionally correct: substituting the benign median for `device_age_days` alone moves the mean fraud score from 0.972 to 0.554, which is below the decline threshold. Whether the policy then uses the capability, and whether using it helps, are separate questions that Section 8.3 answers with a controlled comparison.

## 7.4 VICTIM SELECTION

The attacker makes two decisions of different kinds, and GAUNTLET treats them differently. Executing an attack is sequential, so it is learned with policy gradient. Choosing whom to attack is not, and modelling it as though it were would add variance without adding capability.

Selection has no state transition. A card is drawn from the dump, an episode runs against it, a return is observed, and the next episode begins from an unrelated card. Nothing chosen now alters what is available later, so there is no value function over successor states to estimate, and a sequential method spends its machinery on a problem with no sequence in it.

A plain multi-armed bandit fails for the opposite reason. Several thousand cards treated as independent arms learns almost nothing, because a card is rarely seen twice and the posterior for an arm sampled once carries no information about any other. Modelling the return as linear in the features a purchased dump actually carries generalises across cards that were never sampled, which is the standard contextual formulation (Li et al., 2010). The reward is a continuous episode return rather than a success indicator, which rules out a Beta-Bernoulli likelihood; a Normal-Inverse-Gamma posterior estimates the noise scale instead of assuming it (Agrawal & Goyal, 2013).

Each episode draws a small candidate set, the selector samples a weight vector from its posterior, and the best candidate under that draw is attacked. The realised episode return is then folded back in. Exploration is therefore proportional to the uncertainty that remains rather than governed by a tuned constant, which matters here because the quantity being estimated does not hold still: the attacker improves while the bandit learns, and the defender refits beneath both. The posterior is discounted for that reason. A return from fifty episodes ago describes a world that no longer exists, and down-weighting it lets the estimate track the change rather than average across it.

Selection reads only what a dump carries, which is the issuer BIN tier and a coarse card age band. Not the credit limit, not the balance, not the graph. Those are facts the bank holds, and an attacker permitted to select on them would be answering an easier question than the one posed. Section 8.6 reports what the selector learned to prefer under that constraint.

Table 4: Static detection at 12,000 holders against the scripted red team. PR-AUC is primary; a raised prevalence is used so the ablation delta is stable.

| Detector                  | PR-AUC | R@0.1% | R@1%   |
|---------------------------|--------|--------|--------|
| Rule engine $D_0$         | 0.0266 | 0.0000 | 0.0109 |
| Flat GBDT                 | 0.9879 | 0.9727 | 0.9945 |
| without per-entity        | 0.9876 | 0.9563 | 0.9945 |
| Experts, fixed average    | 0.9262 | 0.9016 | 0.9071 |
| Experts, learned combiner | 0.9370 | 0.8634 | 0.9672 |

## 8 RESULTS

Two regimes are reported and they are not interchangeable. Static detection benchmarks run at 12,000 cardholders against the fixed scripted red team, which is what makes an architectural ablation interpretable: a fixed adversary on fixed data. Co-adaptation runs at 600 cardholders across four paired seeds, because that regime needs many independent runs instead of one large one, and a single run of a heavy-tailed process supports no comparison. Every figure regenerates from the stored run data, and Appendix B lists every configuration value the runs used.

### 8.1 STATIC DETECTION BENCHMARKS

Table 4 reports the detection architectures against the scripted red team at a raised prevalence. The rule engine is the published baseline a learned model has to beat, and it is beaten decisively: PR-AUC 0.0266 against 0.9879 for the flat gradient-boosted tree, which reaches 0.9727 recall at a 0.1% false positive rate.

Two ablations sit in that table and both are reported as they came out. The learned combiner beats the fixed average by 0.0108 PR-AUC, so combining expert opinions is worth learning. The flat tree beats the expert ensemble, which says that at this scale and against this adversary the structural decomposition costs accuracy rather than buying it. The ensemble earns its place on grounds the aggregate score does not show, namely that it produces per-event-type scores an analyst can attribute and that its experts can be retrained independently, but the aggregate number favours the flat model and is stated that way.

The per-entity feature ablation returns a null result. Removing `amount_vs_median`, `is_first_txn_this_merchant`, and their companions changes PR-AUC by +0.0003. Those features do appear in the top twelve by gain, so they are not inert; they are redundant against device age, time since last authorisation, and the entry-mode aggregates, which rank far above them. The per-entity work earned its place in benign fidelity, which is what it was for. A detector facing this red team does not need it.

The cost-curve search places the bands at 0.53 for step-up, 0.63 for hold, 0.74 for decline, and 0.84 for block, against round-number defaults of 0.30, 0.60, 0.80, and 0.95. The learned combiner weights the network expert highest at +14.99, then transaction at +11.89, binding at +7.32, identity at +6.74, and text at +2.00.

### 8.2 CLOSED-LOOP CO-EVOLUTION

Table 5 gives mean extraction per episode within each inter-refit block, for all eight runs. Figure 4 plots the curves.

Five of the eight runs show the full pattern, under the rule that some post-refit block mean exceeds the pre-refit block mean and at least one refit is followed by a drop. Peak extraction exceeds the opening block mean by between 1.4 and 4.8 times across all eight. The three exceptions divide into two kinds. In ablated seeds 0 and 3 the defender takes control at the first refit and never cedes it, which is the loop working in the defender’s favour. In full seed 1 the attacker climbs monotonically and no refit reverses it, which is the loop working in the attacker’s favour; that run reaches the highest final block mean of any in the full arm.

Table 5: Mean value extracted per episode within each inter-refit block, four paired seeds. 600 holders, 24 updates, refit every 6, 2% prevalence.

| Arm     | Seed | pre  | r1   | r2   | r3    | peak  |
|---------|------|------|------|------|-------|-------|
| Full    | 0    | 2687 | 7608 | 2601 | 2155  | 10065 |
| Full    | 1    | 2536 | 2784 | 2880 | 10398 | 12135 |
| Full    | 2    | 2404 | 5116 | 9351 | 4075  | 11364 |
| Full    | 3    | 2358 | 2054 | 4372 | 5062  | 6773  |
| Ablated | 0    | 3295 | 1377 | 1010 | 722   | 4788  |
| Ablated | 1    | 1868 | 3804 | 1805 | 5050  | 6987  |
| Ablated | 2    | 2743 | 4764 | 3845 | 11129 | 12965 |
| Ablated | 3    | 3191 | 2834 | 1307 | 1135  | 4548  |

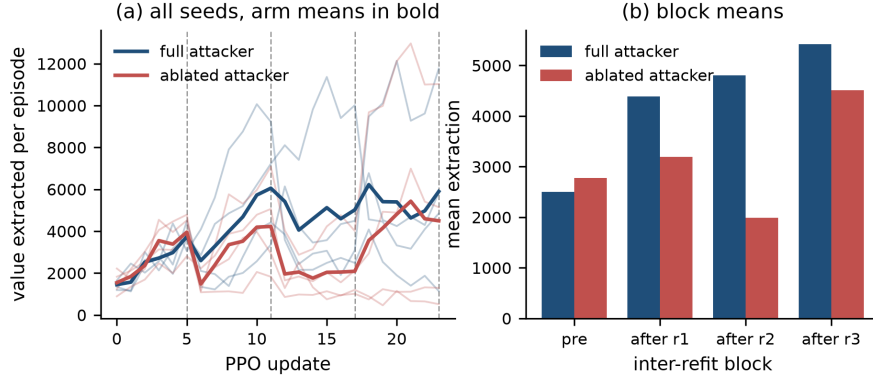


Figure 4: Co-evolution across four paired seeds. Dashed lines mark defender refits. Left: every seed faintly, arm means in bold. Right: mean extraction per inter-refit block. Extraction rises, a refit suppresses it, and the attacker recovers.

The co-evolution appears in both arms. It is a property of the loop rather than of any one attacker capability, and the next subsection separates the two claims.

### 8.3 THE STEALTH ABLATION

The two arms share a world per seed and differ in one respect: the ablated arm has its posture head pinned to the loud setting and its credential dump reduced to a single card, which reproduces the attacker exactly as it stood before those capabilities existed. Table 6 pairs them.

The mean paired difference is +1639 with a 95% bootstrap interval of  $[+219, +2764]$  over 20,000 resamples. The interval excludes zero, so the stealth capability is worth having at this scale.

The caveats are as important as the point estimate. Four seeds is a small sample, one seed runs the other way, and an interval of this width would not detect an effect much smaller than the one measured. The claim supported is that the posture head and the multi-card dump improve the attacker within the loop. The claim not supported is that they cause the co-evolution, which Section 8.2 shows occurring in the ablated arm as well.

### 8.4 EMERGENT STRATEGIES

Table 7 gives the converged strategy sampled before each of the ten refits in the 6,000-cardholder run, with posture annotations. That run is used here rather than the paired seeds because sixty updates trace the progression at higher resolution than twenty-four. These sequences were never scripted; they are what the policy arrived at.

Two things move independently. The posture shifts first, from rotate to aged-cool by update 29, while the binding tactic stays put. The tactic then changes at update 47: `reset_password` replaces



Table 6: Paired comparison of mean post-refit extraction. Positive favours the full attacker.

| Seed | Full | Ablated | Difference   |
|------|------|---------|--------------|
| 0    | 4121 | 1036    | +3085        |
| 1    | 5354 | 3553    | +1801        |
| 2    | 6180 | 6579    | -399         |
| 3    | 3829 | 1759    | +2071        |
| Mean | 4871 | 3232    | <b>+1639</b> |

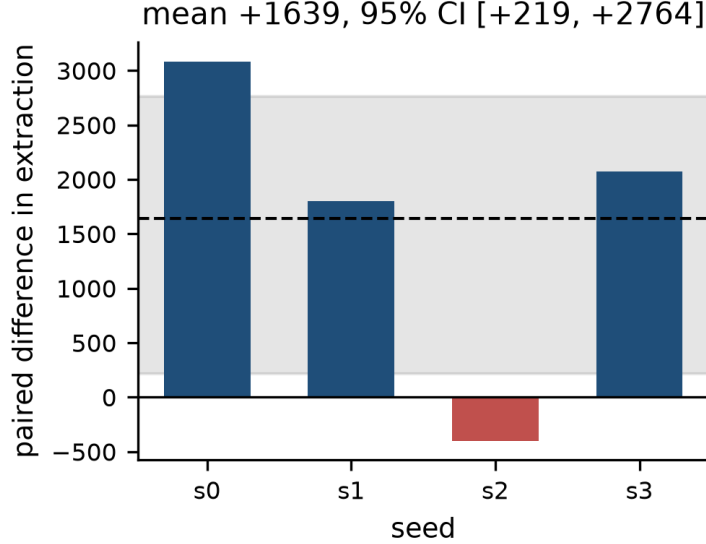


Figure 5: Paired difference in post-refit extraction. Dashed line is the mean; shaded band is the 95% bootstrap interval over 20,000 resamples.

`add_device_selfserve` and holds for the rest of the run. That second route is the quiet one, since it reaches a spendable state without minting a device, so the device-age signal that dominates the detector’s feature importances never fires. Across the paired seeds a third tactic appears, hijacking the number by SIM swap, and all four postures are used.

Strategy diversity rises. Averaged over seeds, the full attacker converges on 1.2 distinct sequences before the first refit and 7.0 by the last; the ablated attacker moves from 1.2 to 5.8, peaking at 7.0 at the second refit. Both arms diversify under pressure, which is consistent with the co-evolution appearing in both. Figure 6 plots it.

## 8.5 DEFENDER FRICTION

A detector that tightens without limit wins any contest measured on recall alone. Figure 7 reports the other side: the share of genuine authorisations the live defender would refuse, measured on the benign traffic generated between refits and scored by the defender then in force.

Against the full attacker the defender refuses 0.67% of genuine authorisations on average across sixteen refits, ranging from zero to 3.0%. Against the ablated attacker the mean is 0.19%, which is the expected direction: a weaker adversary lets the cost curve settle at a looser operating point. Pooled across both arms the mean is 0.43%. The figure to read against the co-adaptation results is the 0.67% one, since that is the configuration those results come from.

Table 7: Converged strategies at each refit, 6,000 cardholders, sixty updates. Bracketed terms are the chosen posture: rot is rotate, cool is aged-cool. Repeated trailing authorisations are elided.

| Update | Converged strategy                              |
|--------|-------------------------------------------------|
| 5      | phish_holder[rot] → add_device[rot] → auth      |
| 11     | buy_creds[rot] → add_device[rot] → auth[rot]    |
| 17     | buy_creds[rot] → add_device[rot] → auth[cool]   |
| 23     | buy_creds[rot] → add_device[cool] → auth[cool]  |
| 29     | buy_creds[cool] → add_device[cool] → auth[cool] |
| 35     | buy_creds[cool] → add_device[cool] → auth[cool] |
| 41     | buy_creds[rot] → add_device[rot] → auth[rot]    |
| 47     | buy_creds[rot] → reset_pwd[rot] → auth[rot]     |
| 53     | buy_creds[cool] → reset_pwd[cool] → auth[cool]  |
| 59     | buy_creds[cool] → reset_pwd[cool] → auth[cool]  |

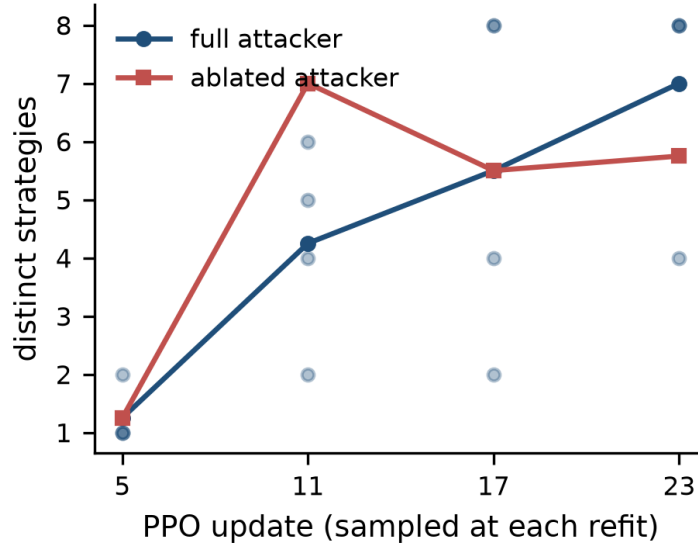


Figure 6: Distinct converged strategies at each refit, averaged over seeds. Faint points are individual seeds of the full attacker.

## 8.6 WHAT VICTIM SELECTION LEARNED

Figure 8 shows the selector’s posterior mean, expressed as differences from a reference level. The values quoted here come from the 6,000-cardholder run, whose posterior is fitted on 1,920 observations against the 288 of a single paired seed.

The strongest preference is for cards more than three years old, at +226.5 against the under-six-month reference, with the one-to-three-year band at −132.0. Nothing told the selector to prefer aged cards. It learned the preference from realised returns, and the preference is sensible: older accounts carry higher limits and longer histories, so an authorisation on one is both worth more and less anomalous. The BIN-tier coefficients are positive across all three non-reference tiers, from +33.6 to +93.3, which reads as a mild preference for anything above the lowest tier rather than a ranking among them.

## 9 REAL-WORLD FEASIBILITY

### 9.1 WHAT DEPLOYS WITHOUT THE SIMULATOR

The defender is an ordinary production architecture and needs none of the apparatus around it. Event-typed experts, a learned combiner over the applicable subset, thresholds placed on a cost curve,

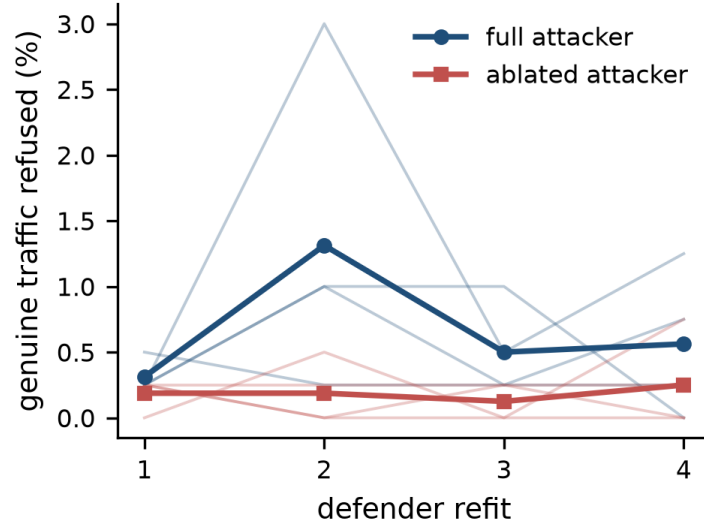


Figure 7: Genuine authorisations refused, per refit. A step-up is friction rather than refusal and is excluded; holds, declines, and blocks all stop the transaction.

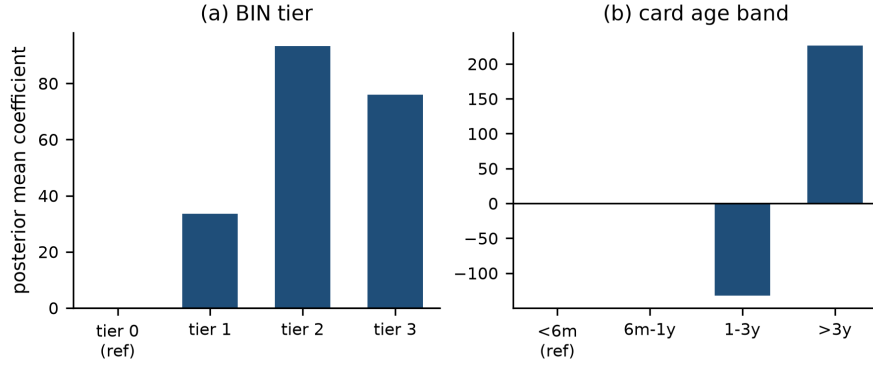


Figure 8: Victim-selection posterior over dump-knowable features. Coefficients are differences from the reference level, which sits at zero by construction.

and mitigations that write back to the entity graph describe a system an issuer could build against its own event stream. Nothing in that design depends on the traffic being synthetic.

Three of its properties are worth adopting independently of anything else in this paper. Routing by event type rather than by a learned gate removes a component that can fail in production, since a misrouted event reaches an expert that has never seen its feature space and returns a number with no meaning. Placing the bands on a cost curve rather than at round numbers makes the operating point a decision someone can defend to a business owner, and makes the friction the detector imposes a reported quantity rather than a discovered one. Mitigations that mutate the graph, rather than raising an alert, mean a removed capability is actually removed; an attacker that loses a device to a blocklist must acquire another and pay for it.

The asymmetric retention scheme transfers directly as well, and follows a finding that predates this work (Dal Pozzolo et al., 2014): retain fraud across refits, retain only recent genuine traffic, and implement that by changing what the model has seen rather than by reweighting a loss.

## 9.2 WHAT THE SIMULATOR IS FOR

The simulator answers a question a production system cannot: what would an adaptive adversary do against this detector, before one arrives. A deployed detector learns about a new attack by losing money to it, and the interval between the attack appearing and the labels arriving is the interval in which the loss accrues. A red-team harness moves that discovery earlier.

The workflow it supports is concrete. Fit the world to an issuer's own aggregate statistics, which requires no cardholder data to leave the institution, since the calibration consumes distributions rather than rows. Insert the current production detector as the defender. Run the loop. Read the strategies the policy converges on, and treat each as a hypothesis about a path that is currently underdefended. The strategies in Section 8.4 are the output format: an action sequence with the posture annotations that make it reproducible.

Two properties make the output actionable rather than merely interesting. The strategies are sequences of real actions against real controls, so each maps onto a specific gap, and the quiet takeover route the policy found in several runs names one directly. And because the defender operates under a cost curve, a strategy that survives is one that survives against a detector which must remain usable, rather than against a detector free to refuse everything.

## 9.3 OPERATING CONSTRAINTS

**Privacy.** The world is synthetic and calibrated to aggregate statistics, so no cardholder record leaves the institution. The calibration inputs are distributions and summary statistics, which is a materially lower bar for data governance than moving transaction-level data into a research environment.

**Compute.** The results here run on a single GPU in hours. The generative pool is built once and reused across every subsequent run, so language model inference is a fixed setup cost, not a per-run one. No component requires a served model at simulation time.

**Liability context.** The cost curve the bands are searched against is not an abstraction. Mandatory reimbursement for authorised push payment scams in the UK places up to GBP 85,000 of liability per case on the sending and receiving institutions ([Payment Systems Regulator, 2024](#)), so the trade between a missed fraud and a refused genuine customer carries a real price on both sides.

**Integration.** The defender consumes an event stream and emits a score and a set of mitigations. Both sides of that interface exist in any real-time decisioning system, so the harness attaches to a shadow-mode replay of production traffic without changes to the production path.

**Reproducibility.** Appendix D gives the commands.

**Governance.** Everything the harness produces is attributable. Each parameter carries a provenance class, each claim carries the scale it was measured at, and each strategy is a logged action sequence marked with what the world did with each action. A finding can be traced to the run that produced it.

## 10 LIMITATIONS

**Zero-shot recall is not reported.** SIM swap is designated a held-out vertical, but the SIM swap action is also legal in the learned attacker's action space, and the policy uses it. The defender therefore trains on SIM swap traffic and is then asked whether it generalises to SIM swap. High recall could not be credited to generalisation and low recall could not be blamed on it, so the measurement is withheld instead of explained away. Removing the held-out actions from the learned attacker's legality mask would restore it.

**Prevalence is stated, not deployed.** Live-phase results are measured at a 2% fraud share against a deployed rate nearer 0.5%. Reaching 0.5% honestly would require roughly six hundred thousand additional benign rows per refit window, which is not tractable at the run counts this comparison needs. The static benchmarks make the same concession for the same reason, and both are reported with the figure stated openly.

**Four seeds.** The bootstrap interval on the ablation is wide and would not detect an effect much smaller than the one measured. One of the four seeds runs against the mean.

**The live defender is narrow.** During co-adaptation the defender trains on what the learned attacker produces, which is one attack shape per round over a few hundred rows. A deployed detector sees many attack types concurrently and would be correspondingly harder to displace. Running the scripted verticals alongside the learned attacker during the live phase would close this gap.

**Capability tiers are ordinal.** The generative capability ladder is anchored to published benchmark ladders (Todisco et al., 2019; Liu et al., 2023; Wang et al., 2025; National Institute of Standards and Technology, 2023; Li et al., 2020; Dugan et al., 2024), which are not cardinally comparable across editions, and the benchmark organisers say so. Claims take the form that success rises with capability across the swept range. No absolute per-tier success rate is claimed.

**Merchant collusion is absent.** It is described in the taxonomy and excluded from simulation, for the reasons given in Section 4.

## 11 CONCLUSION

Fraud detectors are fitted to fraud that has already happened, and generative models have shortened the interval over which that assumption holds. GAUNTLET addresses the gap by generating the attacks instead of waiting for them, inside a payment world calibrated closely enough to real traffic that a detector evaluated there is being tested rather than flattered.

The design choice that separates this from the obvious alternative, argued in Section 1.2, is that the attacker learns. A language model in an orchestration loop can enumerate plausible attacks; it cannot get measurably better at defeating a particular detector over a thousand episodes, and it cannot be held fixed while one capability is removed. The results depend on both properties. Co-evolution appears in five of eight runs and the attacker gains ground in six, the stealth ablation resolves with a bootstrap interval excluding zero, and the strategies the policy converged on include a quiet account-takeover route that the device-novelty signal does not cover.

The defender is a production architecture that deploys on its own. The simulator is what an institution runs beforehand, to find out which paths through its controls pay off while the finding is still cheap.

## REFERENCES

- Shipra Agrawal and Navin Goyal. Thompson sampling for contextual bandits with linear payoffs. In *International Conference on Machine Learning (ICML)*, pp. 127–135, 2013.
- Alejandro Correa Bahnsen, Djamila Aouada, Aleksandar Stojanovic, and Björn Ottersten. Feature engineering strategies for credit card fraud detection. *Expert Systems with Applications*, 51: 134–142, 2016.
- Board of Governors of the Federal Reserve System. The federal reserve payments study. Technical report, Federal Reserve, 2024.
- Tianqi Chen and Carlos Guestrin. XGBoost: A scalable tree boosting system. In *ACM SIGKDD International Conference on Knowledge Discovery and Data Mining*, pp. 785–794, 2016.
- Consumer Financial Protection Bureau. Consumer complaint database. <https://www.consumerfinance.gov/data-research/consumer-complaints/>, 2025. Public domain; narrative subset used, 2022 and earlier.
- Andrea Dal Pozzolo, Olivier Caelen, Yann-Aël Le Borgne, Serge Waterschoot, and Gianluca Bontempì. Learned lessons in credit card fraud detection from a practitioner perspective. *Expert Systems with Applications*, 41(10):4915–4928, 2014.
- Liam Dugan, Alyssa Hwang, Filip Trhlík, Josh Magnus Ludan, Andrew Zhu, Hainiu Xu, Daphne Ippolito, and Chris Callison-Burch. RAID: A shared benchmark for robust evaluation of machine-generated text detectors. In *Annual Meeting of the Association for Computational Linguistics (ACL)*, 2024.
- European Banking Authority and European Central Bank. Joint report on payment fraud. Technical report, EBA/REP/2025/40, 2025.

- David Freeman, Sakshi Jain, Markus Dürmuth, Battista Biggio, and Giorgio Giacinto. Who are you? a statistical approach to measuring user authenticity. In *Network and Distributed System Security Symposium (NDSS)*, 2016.
- Brandon Harris. Credit card transactions fraud detection dataset. Kaggle, CC0 public domain, 2020. Sparkov generator; used for category taxonomy only.
- IEEE Computational Intelligence Society and Vesta Corporation. IEEE-CIS fraud detection. Kaggle competition dataset, 2019. 590,540 card-not-present transactions, 394 features.
- Lihong Li, Wei Chu, John Langford, and Robert E. Schapire. A contextual-bandit approach to personalized news article recommendation. In *International Conference on World Wide Web (WWW)*, pp. 661–670, 2010.
- Yuezun Li, Xin Yang, Pu Sun, Honggang Qi, and Siwei Lyu. Celeb-DF: A large-scale challenging dataset for deepfake forensics. In *IEEE/CVF Conference on Computer Vision and Pattern Recognition (CVPR)*, pp. 3207–3216, 2020.
- Xuechen Liu, Xin Wang, Md Sahidullah, Jose Patino, Héctor Delgado, Tomi Kinnunen, Massimiliano Todisco, Junichi Yamagishi, Nicholas Evans, Andreas Nautsch, and Kong Aik Lee. ASVspooF 2021: Towards spoofed and deepfake speech detection in the wild. *IEEE/ACM Transactions on Audio, Speech, and Language Processing*, 31:2507–2522, 2023.
- Edgar Alonso Lopez-Rojas, Ahmad Elmir, and Stefan Axelsson. PaySim: A financial mobile money simulator for fraud detection. In *European Modeling and Simulation Symposium (EMSS)*, pp. 249–255, 2016.
- National Institute of Standards and Technology. Face analysis technology evaluation: Presentation attack detection. Technical Report NIST IR 8491, NIST, 2023.
- Yoshihiko Ogata. On Lewis’ simulation method for point processes. *IEEE Transactions on Information Theory*, 27(1):23–31, 1981.
- T. Ozaki. Maximum likelihood estimation of Hawkes’ self-exciting point processes. *Annals of the Institute of Statistical Mathematics*, 31:145–155, 1979.
- Payment Systems Regulator. Authorised push payment scams: Mandatory reimbursement requirement. Technical report, PSR, 2024.
- Qwen Team. Qwen3-Embedding: Multilingual text embedding models. Alibaba Group technical report, 2025.
- John Schulman, Philipp Moritz, Sergey Levine, Michael I. Jordan, and Pieter Abbeel. High-dimensional continuous control using generalized advantage estimation. In *International Conference on Learning Representations (ICLR)*, 2016.
- John Schulman, Filip Wolski, Prafulla Dhariwal, Alec Radford, and Oleg Klimov. Proximal policy optimization algorithms. *arXiv preprint arXiv:1707.06347*, 2017.
- Massimiliano Todisco, Xin Wang, Ville Vestman, Md Sahidullah, Héctor Delgado, Andreas Nautsch, Junichi Yamagishi, Nicholas Evans, Tomi Kinnunen, and Kong Aik Lee. ASVspooF 2019: Future horizons in spoofed and fake audio detection. In *Interspeech*, pp. 1008–1012, 2019.
- UK Finance. Annual fraud report 2025. Technical report, UK Finance, 2025.
- Xin Wang, Héctor Delgado, Hemlata Tak, et al. ASVspooF 5: Design, collection and validation of resources for spoofing, deepfake, and adversarial attack detection. *Computer Speech and Language*, 2025. arXiv:2408.08739.
- C. Whitrow, D. J. Hand, P. Juszczak, D. Weston, and N. M. Adams. Transaction aggregation as a strategy for credit card fraud detection. In *Data Mining and Knowledge Discovery*, volume 18, pp. 30–55, 2009.
- David H. Wolpert. Stacked generalization. *Neural Networks*, 5(2):241–259, 1992.



## A GENERATION PROMPTS

Three verticals present text to a control: a disputed charge, a support request, and a refund claim. Each prompt is built from a system turn and a user turn filled with facts the simulator supplies, which are the amount, the merchant, the date, and a persona drawn from pools that the fraudulent and benign classes share.

Two disciplines govern the design. First, the two classes share a template. The negative twin of a fraudulent dispute is a real customer disputing a charge they genuinely did not make; the letter reads the same, and the only difference is whether the underlying transaction was authorised, which is a fact recorded in the episode label and not in the text. Drawing the two classes from different templates would teach a text model to recognise the template, and the reported score would describe that. Second, the capability tier is richness, not intent. A higher tier asks for more specific, better-structured text with a timeline and cross-referenced detail. It never asks the model to do anything adversarial, and the ladder stays ordinal and measurable, which is what the capability claim requires.

### A.1 SYSTEM TURN

You are writing on behalf of a bank customer. Produce only the letter or message text, no preamble, no explanation, no subject line unless asked. Write naturally, as a real person would: plain language, occasional imperfection, specific concrete detail. Do not use placeholders like [NAME] or [DATE]; use the details provided. Length: {length.hint}.

### A.2 THE CAPABILITY LADDER

The tier sets the length hint and, at the top tier, adds one instruction that asks for more checkable detail. Table 8 gives both.

Table 8: The capability ladder. Length and specificity grow together; the instructions never become more adversarial. Tiers 0 to 2 carry no additional instruction.

| Tier    Length hint |                                                                 |
|---------------------|-----------------------------------------------------------------|
| 0                   | 2 to 3 terse sentences                                          |
| 1                   | a short paragraph                                               |
| 2                   | 3 to 4 paragraphs with a clear order of events                  |
| 3                   | 4 to 6 paragraphs with a clear timeline and specific references |

| Vertical | Additional instruction at tier 3                                                                                               |
|----------|--------------------------------------------------------------------------------------------------------------------------------|
| Dispute  | Reference long account tenure and that this has never happened before, and request a written response within 10 business days. |
| Ticket   | Provide plausible partial account details and pre-empt the agent’s security questions to build rapport.                        |
| Refund   | Reference a tracking number, describe the problem specifically, and mention prior positive experience with the merchant.       |

### A.3 USER TURNS

Each user turn is shown with the single clause that differs between the fraudulent and benign twin marked. Everything else is identical.

#### Dispute.

Write a card dispute message to {bank}. The customer is disputing a charge of \${amount} at {merchant} on {date}.

The customer's position: **[stance]**. They want it resolved.  
Customer persona: {persona}. Tone: {tone}. Mention the  
amount, the merchant, the date, and how they noticed it  
({detail}). {tier\_extra}

**[stance]** is *they did not authorise this charge and do not recognise the merchant* in the fraudulent case, and *the charge is wrong, they were double-billed and want the duplicate reversed* in the benign case.

#### Support ticket.

Write a support request to {bank}'s customer service. The  
customer needs help quickly because {detail}. They are **[own-  
ership]**. Do not sound scripted. Customer persona: {persona}.  
Tone: {tone}. {tier\_extra}

**[ownership]** is *asking the agent to help them regain access on their behalf* in the fraudulent case, and *asking for help with their own account, which they are locked out of* in the benign case. The pretext and the real emergency read alike; the difference is whether the account belongs to the writer.

#### Refund claim.

Write a refund request to {merchant} for an order of  
\${amount} placed on {date}. The customer says {detail},  
and **[stance]**. Customer persona: {persona}. Tone: {tone}.  
Include the order amount and date. {tier\_extra}

**[stance]** is *they have not returned the item and are requesting a full refund* in the fraudulent case, and *they returned the item and are requesting the refund they are owed* in the benign case.

### A.4 TEXT SCORES

Three scores accompany each generated artifact and are what the text expert consumes. Template similarity compares the artifact against the human CFPB corpus and against other artifacts at the same tier, using a hashed n-gram representation so the comparison is linear in corpus size. Entity consistency checks the amounts, dates, and merchant names in the text against the event fields the artifact accompanies, which is where a higher-tier generation earns its advantage. A perplexity proxy scores fluency. All three are measured properties of the output, which is what keeps the tier ladder from being circular: the tier is defined by the prompt, and its effect is observed rather than assumed.

## B HYPERPARAMETERS

Table 9 lists every value used in the reported runs. Reward weights are design parameters tuned until the simulation behaves and are never presented as empirical, in keeping with the provenance scheme of Section 3.2. The two cost figures in the band search are vendor-sourced order-of-magnitude estimates, which is why no dollar return on investment is claimed anywhere in this paper.

## C ACTION SPACE

Twenty actions span the four stages. Table 10 gives them with the stage each is legal from and the cost it carries. Actions marked with a dagger request a generated artifact before they resolve.

Two transitions reach the monetised stage: an authorisation, which extracts its amount on approval, and a peer-to-peer transfer, which moves balance into a laundering pot and realises value only at a later cash-out. The distinction matters for reward design, since a bonus paid on arrival at the stage would pay the transfer for extracting nothing.

Table 9: Configuration for the reported runs.

| Group   | Parameter                | Value                |
|---------|--------------------------|----------------------|
| PPO     | discount $\gamma$        | 0.99                 |
|         | GAE $\lambda$            | 0.95                 |
|         | clip $\epsilon$          | 0.2                  |
|         | entropy coefficient      | 0.01                 |
|         | gradient clip            | 0.5                  |
|         | actor learning rate      | $3 \times 10^{-4}$   |
|         | critic learning rate     | $1 \times 10^{-3}$   |
|         | epochs per update        | 4                    |
|         | minibatch size           | 256                  |
|         | hidden width, layers     | 256, 2               |
|         | KL-to-clone coefficient  | 0.5                  |
|         | KL anneal over           | 20 updates           |
| Reward  | value scale              | 0.05                 |
|         | detection penalty        | 2.0                  |
|         | failed action penalty    | 0.25                 |
|         | stage advance bonus      | 1.0                  |
|         | monetisation bonus       | 10.0                 |
| Episode | action cap               | 40                   |
|         | duration cap             | 720 h                |
|         | per-merchant value cap   | 2000                 |
|         | threshold jitter         | $\pm 0.03$           |
|         | non-progress limit       | 6 steps              |
|         | cool-off floor           | 1200 min             |
| Loop    | holders                  | 600                  |
|         | PPO updates              | 24                   |
|         | episodes per update      | 12                   |
|         | refit every              | 6 updates            |
|         | label latency            | 2880 min             |
|         | fraud retained           | 3 refits             |
|         | benign retained          | 3 refits             |
|         | target prevalence        | 0.02                 |
|         | demonstration episodes   | 40                   |
|         | behaviour cloning epochs | 6                    |
|         | critic rollouts, epochs  | 16, 8                |
|         | dump size                | 3 cards              |
|         | selection candidates     | 5                    |
| Bands   | friction cost            | 5.0                  |
|         | review cost              | 8.0                  |
| Text    | generation model         | Qwen-2.5-7B-Instruct |
|         | embedding model          | Qwen3-Embedding-0.6B |
|         | embedding dimension      | 256                  |
|         | pool entries             | 12000                |

## D REPRODUCING THE RESULTS

**Install.** The package must be installed before anything runs: the code lives under `src/`, so a checkout alone is not importable.

```
pip install -r requirements.txt
pip install -e .
```

**Data.** A clone carries the fitted calibration parameters, the measured noise floors, and the generated text corpus with its embeddings, so no model download and no GPU is needed. The four public source datasets are not redistributed; place them under `Dataset/` as `ieee-fraud-detection/`, `sparkov/`, `paysim/` and `complaints/`, or point `GAUNTLET_DATASET` elsewhere. Only `complaints/cfpb_payments.all.parquet` is read at run time, where it supplies the refer-

Table 10: The action space. † marks actions that request a generated artifact. Costs are design parameters.

| Action               | Legal from       | Cost |
|----------------------|------------------|------|
| phish_holder †       | NONE             | 1.0  |
| buy_creds            | NONE             | 2.0  |
| make_synth_id        | NONE             | 3.0  |
| harvest_voice †      | NONE, ACQUIRED   | 1.5  |
| harvest_face †       | NONE, ACQUIRED   | 1.5  |
| call_ivr_provision   | ACQUIRED         | 3.0  |
| submit_kyc           | ACQUIRED         | 3.0  |
| add_device_selfserve | ACQUIRED         | 1.0  |
| sim_swap †           | ACQUIRED         | 5.0  |
| reset_password       | ACQUIRED         | 1.0  |
| add_payee            | ACQUIRED, BOUND  | 1.0  |
| open_ticket †        | BOUND            | 2.0  |
| escalate_limit       | BOUND            | 2.0  |
| attempt_auth         | BOUND, MONETIZED | 0.5  |
| complete_3ds         | BOUND            | 1.0  |
| transfer_p2p         | BOUND            | 0.5  |
| request_refund †     | BOUND            | 2.0  |
| file_dispute †       | MONETIZED        | 2.0  |
| cash_out             | MONETIZED        | 1.0  |
| launder_chain        | MONETIZED        | 2.0  |

ence narratives the text scorer compares generated complaints against. If it is absent the scorer falls back to scoring the corpus against itself, which changes the text expert’s inputs without reporting an error. The remaining sources are read only when refitting calibration.

### Run.

```
python main.py
python main.py coadapt --profile ablation --seed 1
python main.py control --profile ablation --seed 1
python -m fraudsim.orchestration.ablation
python make_figures.py
```

Profiles set sizes and never which stages run or what they print. There are five: `quick`, `ablation`, `default`, `gpu` and `server`. A bare `python main.py` runs `default`; every static benchmark comes from `server`. The co-adaptation results in Section 8 come from four paired seeds of the second and third commands under `ablation`, which is the profile that fixes 600 cardholders, 24 updates and a refit every 6.

A seeded `coadapt` or `control` run writes its metrics into `artifacts/ablation/` under the name the reader expects, so the commands above work in that order with nothing copied by hand. The reader recomputes the paired comparison and its bootstrap interval from those stored files, and `make_figures.py` draws the figures from the same files, taking its statistics from the `ablation` module rather than recomputing them. Every number therefore traces to a run artifact rather than to a transcription.

**Tests.** The suite covers the simulator, the calibration protocol, the defender, the attacker, and each of the five episode integrity controls, with 417 tests and no skips. The five controls each carry a test asserting the control changes what the world permits, since a control declared in configuration and enforced nowhere would pass silent inspection while producing results that measure its absence.